言行 银行 AI 智能体技术文档

项目全称：言行——融合任务规划与分级授权的多场景银行 AI 智能体

速发贝团队　参赛技术文档　提交版 1.0　2026 年 11 月 1 日

本文说明言行 2.0.0 的系统架构、模型 API、核心算法、安全设计与实际验证范围。模型理解需求并提出计划，可信程序校验资源、身份、授权和执行。项目覆盖六类本地模拟金融业务，界面采用统一柔彩视觉系统；资金规则、认证和模型调用边界保持不变。

本版对应 2026 年 11 月 1 日整理的提交快照，产品版本 2.0.0；源码基线为 e555721b 及已验收的团队署名、文档和测试夹具修订。精确文件版本由源码包内文件清单与 SHA256 确定，本文不以历史测试替代当前检查。

1 项目定位与实现范围

用户可以用自然语言提出单项业务，也可以提出包含多个步骤的需求。系统补齐金额、对象和日期等必要信息，将可执行部分编译为受约束的业务请求。遇到同名收款人、问卷缺项或时间安排不明确时，系统要求补充信息，不自行编造业务条件。

项目面向本机单用户演示。账户余额、金融产品、银行卡、商户订单及配送均为模拟数据；外部大模型 HTTP 接口和本机密码、手机验证器动态码使用实际技术实现。真实身份验证的实现不意味着已经接入真实银行支付系统。

场景	当前主要能力	演示边界
智能转账	收款人解析与消歧 单笔及定时转账 AA 收款单	到期付款重新计算权限并等待授权 AA 建单不代表收款
账单分析	上海日期聚合 分类统计 退款单列 大额单笔提示	仅启用已经确定的统计与提示规则
理财服务	产品对比 五题风险测评 申购 持仓 赎回	产品和净值虚构 无真实市场交易及跨日清算
卡片服务	申请受理 限额 冻结 解冻 挂失 解挂	申请受理不代表真实审批或发卡
订阅管理	识别 核实 排除 取消 每期续费 本地提醒	续费逐期授权 提醒为站内记录
生日联动	日期计划 月度预算预留 到期准备 选卡下单 余款释放	订单需逐笔授权 不提供真实采购配送

跨场景联动的价值在于保留步骤之间的依赖关系。例如，先完成风险测评再申请模拟理财申购，或先预留预算再准备生日采购。前置步骤失败或结果未知时，后续依赖步骤不能把它当作成功继续执行。

2 系统架构与数据流

系统采用 Python、Streamlit 和 SQLite。页面负责交互，模型客户端负责受控 HTTP 通信，计划编译器负责把自然语言结果转换为已有业务动作，银行网关负责身份、权限、业务条件、幂等和事务。独立后台进程检查到期事项，通过同一网关准备业务，不能代替用户批准交易。

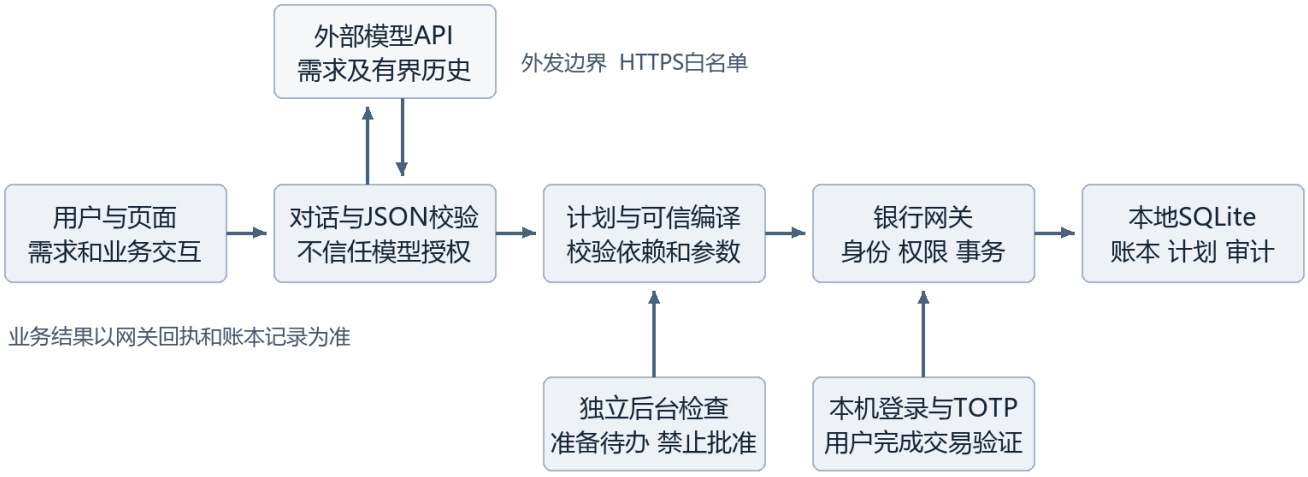


图 1 模型交互与可信业务执行的关系

层次	主要职责	核心源码
交互层	首次设置 登录 模型设置 任务及授权展示	app/main.py 及 app 下相关面板
理解与规划层	多轮补充 JSON 校验 依赖校验 可信业务编译	agent/model_dialogue.py 与 model_bank.py
模型通信层	服务商配置 地址校验 请求 响应和异常处理	agent/model_providers.py 与 model_client.py
执行与认证层	归属校验 动态权限 挑战 TOTP 原键恢复	bank/gateway.py 与 auth.py
持久化与后台	账本 计划版本 事件 工作租约 站内通知	bank/store.py plan_store.py worker.py

一轮对话先由页面接收需求，再由客户端向所选模型发送系统提示、用户输入和有界对话历史。响应经过传输层和业务层两次检查后形成草稿或计划。执行时，编译器从当前可信业务上下文读取账户及资源，不以模型提供的身份或授权状态为准。网关返回待确认、待验证、成功、失败、已登记或未知等状态，页面按这些状态展示下一步。

外部模型请求会离开本机。历史中可能包含此前的需求和模型草稿，不能因为账本使用 SQLite 就声称全部数据只在本地。当前演示应使用虚构信息；自动脱敏、用户真实资料对外发送策略和供应商侧留存管理不属于已经完成验收的能力。

3 多服务商模型 API 接入

3 1 服务商与配置方式

设置页提供 DeepSeek、智谱 GLM、通义千问、豆包和 Kimi。每家服务商绑定对应地址，可选择预设模型或填写受限格式的自定义模型 ID。下表描述当前源码配置，不表示所有预设模型已通过实时可用性检查，也不保证任意兼容接口具有相同行为。

服务商	当前允许的 HTTPS 基础地址	对应环境变量
DeepSeek	https://api.deepseek.com	DEEPSEEK_API_KEY
智谱 GLM	https://open.bigmodel.cn/api/paas/v4	ZHIPU_API_KEY 或 ZAI_API_KEY
通义千问	https://dashscope.aliyuncs.com/compatible-mode/v1	DASHSCOPE_API_KEY
豆包	https://ark.cn-beijing.volces.com/api/v3	ARK_API_KEY
Kimi	https://api.moonshot.cn/v1	MOONSHOT_API_KEY

这些地址来自 agent/model_providers.py，发送时在基础地址后追加 /chat/completions。豆包等服务还可能需要用户账户中实际可用的模型或推理接入点 ID。模型名称能在页面保存，只说明本地格式校验通过；远端权限、额度和协议仍须实际请求验证。

配置由 BANK_MODEL_PROVIDER、BANK_MODEL_BASE_URL、BANK_MODEL_NAME 等项目参数和对应服务商密钥共同确定。密钥读取优先检查显式通用配置，再检查所选服务商环境变量，最后读取匹配的已保存配置。保留旧 DeepSeek 配置的兼容逻辑，避免升级后默认服务商被悄悄改变。

本地保存的是一份当前服务商配置，不是同时保存五份密钥的保险库。配置 v2 将服务商和加密密钥绑定；切换服务商时清除旧密钥关联，要求输入该服务商的新密钥。Windows DPAPI 负责本地静态加密，读取时才在进程内解密。旧 v1 配置按 DeepSeek 解释，仅仅读取不会强制重写配置文件。可选桌宠凭据复用仅适用于 DeepSeek，且需用户选择并具备原桌宠开发环境；源码包附只读桥接脚本，随附历史安装器未包含该脚本，安装版应独立填写模型密钥。

3 2 请求协议与边界

客户端采用非流式 JSON 请求，设置 response_format 为 json_object，最大输出参数为 4096 tokens。它只接收 role 和 content 消息字段，并对不同服务商设置当前实现需要的思考参数。模型调用与业务执行分开；响应中的 tool_calls 不会成为可执行工具调用。

响应首先检查 HTTP、大小、编码和外层 JSON，再检查结束状态、模型标识及正文 JSON。只有结构符合对话协议的结果才交给规划层。模型截断、错误格式或额外工具调用都不能绕过校验进入银行业务。当前客户端会在请求前拒绝以 kimi-k3 或 kimi-k2.7 开头的模型 ID；这是本项目客户端的兼容边界。

项目	当前限制或行为
传输消息数	1 至 40 条
HTTP 请求体	不超过 65536 字节 即 64KiB
HTTP 响应体	不超过 262144 字节 即 256KiB
请求超时	默认 45 秒
跳转与重试	禁止 HTTP 重定向 不自动重试 不自动切换服务商
远端地址	服务商与 HTTPS 主机及路径白名单匹配 禁止用户信息 查询参数和片段
本地兼容地址	仅允许代码限定的 127.0.0.1 或 IPv6 回环地址及路径 尚无本地模型安装实测

401、402、429 等错误转换为密钥无效、余额不足或限流提示；其余异常使用受控说明，不把远端原始异常直接当成面向用户的消息。记录的调用元数据包含服务商、返回模型和允许的 token 计数，既不等于费用账单，也不能单凭这些字段推断业务已经完成。

3 3 已有 API 验证范围

2026 年 10 月 28 日归档的 DeepSeek 复验，按“白金卡”名称完成冻结和解冻两次页面操作，经临时身份 TOTP 验证，刷新未重复调用；不等于本人手机签收。原 5 元测试账本累计 20 次、预留 5 元，用量估算上界 0.097314 元，非实际扣费。历史在线记录保留原版本，不合并成当前全场景成功率；其他四家未在线复验。

后续实际 API 验收应记录服务商、请求模型、返回模型、日期、用例、次数和成功失败原因，使用虚构业务数据并遵守已批准额度。密钥只在本机配置，不能进入截图、参赛源码包或报告附件。

4 需求理解与任务规划

4 1 多轮补充与修改

对话输出分为澄清、单项草稿、多项计划和不支持四类。合法槽位限定为业务所需参数，例如收款人描述、金额、时间和产品编号。系统不接受模型填写 principal_id、confirmed、proof_token、risk_level 等受保护字段；风险问卷也必须逐题明确作答，不能用一句“保守型”补成完整分数。

用户修改未执行步骤时，系统保留已经完成步骤及其操作键和回执。已执行步骤不能通过改名、改号或重新构建计划变成一笔新付款。暂停、回退或人工接管只控制后续流程，不撤销已经入账的模拟交易。

4 2 依赖校验与执行

计划最多 20 步，每步包含唯一编号、意图、参数和依赖。对话层与执行层均检查依赖存在、编号唯一及无环。跨步骤引用仅能使用成功依赖祖先回执中的受支持资源，例如预算预留编号或风险档案编号，不能直接采用模型编造的引用。

执行器在依赖就绪后重新编译业务动作。允许的纯查询可自动推进，其他动作由用户准备或由已启用的后台准备，再进入网关规定的确认或验证。风险测评虽属于绿色动作，但会持久化风险档案，不能把“绿色”笼统理解为“只读”。

scheduled 表示未来业务已经登记，只有到期后实际执行回执才能证明付款完成。unknown 表示结果未能确定，须保留原动作和原操作键查询；依赖该结果的步骤停止推进。模型回复中的成功文字不能替代这些状态。

规划侧边界	当前实现
单次需求	1 至 1000 字符
JSON 结构	最大深度 16 最大节点 4096 拒绝重复键
模型草稿文本	最多 30000 字符
对话历史	默认 12 条 上限 32 条 序列化累计不超过 24000 字符
计划任务	1 至 20 步
连续异常草稿	5 次后停止当前会话 可核实后开启新需求

这些控制限制已覆盖的结构复杂度与错误传播范围，不构成完整的服务级流量管理、攻击检测或主机沙箱。

5 计划持久化与中断恢复

PlanStore 保存经过校验的计划快照，包括任务、依赖、回执、等待状态、暂停状态、已选资源和后台自动检查偏好。快照不保存完整聊天记录、模型密钥或交易验证凭证，UTF8 大小上限为 262144 字节。计划快照和计划事件在同一事务中更新。

每个计划关联用户和修订号。保存时比较修订号，旧页面不能静默覆盖较新的计划；相同快照不必重复增加版本。恢复后仍使用原来的业务操作键和已知回执，通过可信网关核实未决结果，而不是根据模型文本重建交易历史。

会话失效或程序重启后，登录可恢复持久计划，但不批准付款。未决业务旁可继续提问、澄清、修改草稿和执行纯查询；新写操作仍按原冲突与授权检查。unknown 原请求、原键、资金占用及已保存原计划保持，不能靠刷新或清草稿消除。订阅读取仍需黄色确认，真实红色业务仍需当次动态码。

故障恢复遵循三个顺序：先定位原操作，再核实可信结果，最后决定是否继续依赖步骤。查询不到结果只说明当前查询无记录，不能据此自动换键付款，或释放可能已经被消费的预留金额。

6 业务规则与资金一致性

6 1 资金与授权

金额以整数分存储，计算费用与份额时使用 Decimal。账本保持余额等于可用金额加预留金额。转账日累计取同一用户跨付款账户的上海执行日账本数据；含本次累计不超过 100000 分时黄色确认，超过时红色验证。累计与资源状态在授权执行阶段重新检查，避免授权等待期间的变化被忽略。

写操作绑定幂等键。同键同内容返回原结果，同键变更内容拒绝。资金变化、业务记录、操作结果与审计在相应事务或保存点内关联处理。发生回执丢失或超时，不把客户端错误等同于资金未变动；保留原键恢复可以避免重复提交。

6 2 账单与订阅

账单以上海日期汇总，消费与订阅借方计入毛支出，退款贷方另列；收入、转账和理财不计入消费毛支出。大额单笔提示检查消费、订阅、转账和理财借方达到 5000 元的记录。未确定的借贷配对、跨期退款归属或收益率规则不作自动推定。

订阅候选按账户和商户分组，至少两期符合条件的消费或订阅流水才进入周期判断。按首期锚日推算自然月或年，短月截断到月末，日期容差为前后 3 天，相邻金额差不超过前一期的 5%。重复扫描不重复建候选，已取消商户不会因扫描自动恢复。识别和核实均不意味着同意续费，每期收费仍需独立红色验证。

6 3 理财与卡片

风险问卷 wpq_v1 共五题，每题 1 至 4 分，总分 5 至 20 分；5 至 8、9 至 12、13 至 16、17 至 18、19 至 20 分别映射 R1 至 R5。缺题、额外题号、非法选项和版本不符拒绝。申购检查产品、风险匹配、起购金额与可用余额，赎回检查持仓归属、锁定状态、份额与到账范围。

申购费按基点计算并四舍五入到整数分，净申购金额除以模拟净值后，份额保留四位小数。赎回先计算金额再扣费。当前净值固定，不提供真实收益承诺；赎回使用即时入账的模拟处理，没有真实跨日清算队列。卡片申请只生成受理结果，状态和限额调整均遵守现有网关权限。

6 4 生日联动资金示例

以下为独立临时模拟账户的双订单示例，金额全部为分。先预留 100000 分，随后分别支付鲜花 19900 分和蛋糕 15800 分，最后释放已经核实可用的余款。该示例说明资金关系，不代表真实购买，也不能与有其他前序交易的页面演示余额混用。

阶段	余额	可用金额	预留金额
初始	200000	200000	0
确认预留 100000	200000	100000	100000
验证后支付鲜花 19900	180100	100000	80100
验证后支付蛋糕 15800	164300	100000	64300
确认释放剩余 64300	164300	164300	0

预算预留不减少总余额，订单支付同时减少余额与对应预留，释放余款只将预留转回可用。任一订单结果未知时，先核实原订单，不能把对应金额当作可释放资金。

7 本机登录与手机验证

首次可体验示例账户或设置本机账号，共用同一示例账本。设置账号要求回环监听与有效 Host，用户名最多 64 字符，密码 12 至 256 字符，随机盐加 scrypt 保存；生成 8 个恢复码，确认保存并绑定手机后进入业务。已初始化账号不能降级为体验模式，重复或并发初始化不能覆盖账户。

TOTP 由独立验证器产生，动态码为 6 位、30 秒一步，接受当前及相邻步，但已消费步不能重放。绑定也消费对应动态码，因此刚用于绑定的码不能立即用于交易。TOTP 密钥用 Windows DPAPI 加密保存。

密码登录生成有时限会话，服务端保存会话令牌摘要，当前期限为 3600 秒。连续 5 次错误密码触发 600 秒锁定，TOTP 失败也有独立计数与锁定。交易挑战有效期 10 分钟；真实验证模式要求 v1.2 的 totp 方法，证明绑定当前会话和挑战，普通确认不能替代红色验证。

手机丢失时，用户须提供正确密码及一个未使用恢复码。恢复会消耗该码、撤销原会话和旧绑定，之后重新绑定验证器；没有“忘记密码直接跳过验证”的流程。初始化未确认保存时的恢复材料经过加密暂存，确认后删除可恢复显示的完整材料，仅保留后续核验所需摘要。

当前身份体系限定为本机单用户。自动化使用临时身份和实际 TOTP 算法覆盖相关流程，用户本人手机扫码、实际操作和最终体验签收尚未完成。

8 后台任务与程序生命周期

后台检查须由用户在程序内启用。独立 worker 使用数据库租约防止重复领取和并行运行，保存心跳与状态，检查到期转账、商户任务、提醒及启用自动检查的计划。后台只推进可准备的工作，不能签发或消费用户付款授权，也不会在检查循环中调用付费模型。

生日计划可以结合月度预算节点和生日提前两天的采购节点准备待办。用户仍须确认预算预留，并对订单逐笔完成相应验证。日期冲突、已过采购时间或其他无法由既定规则唯一决定的安排，必须明确选择，不能靠后台自行猜测。

关闭浏览器标签页不会自动结束独立后台进程。程序内正常退出会请求停止后台，再结束页面服务，并保留此前偏好，供后续启动和登录时恢复；明确点击停用后台则关闭偏好。停止后不再领取新任务，已经开始的处理可以完成；未决结果仍保留原状态。

通知保存在本地数据库并在程序内显示，可按业务状态去重。目前没有短信、邮件或 Windows 系统弹窗通知，也没有安装系统服务、开机自启或云端常驻运行。电脑关机期间不能依赖本机进程执行任务。

9 运行与版本约定

源码已在 Python 3.12.14、Streamlit 1.65.0、pyotp 2.10.0、qrcode 8.2 及 openpyxl 3.1.5 环境验证，可通过启动银行助手.py 运行。随源码包提供已验收的 Windows x64 2.0.0 安装器，内置 Python 3.14.10 及 42 个固定 wheel，普通使用无需另装 Python；不是云部署或 Windows 系统服务。

安装版默认监听 127.0.0.1:8511，数据在%LOCALAPPDATA%\言行\data；源码版默认 8501，数据在 runtime 目录。首次设置检查监听地址及 Host。默认共享接口 v1.1，真实 TOTP 交易兼容 v1.2，存储版本 16。

启动、停止和卸载快捷方式位于桌面 other；升级和默认卸载保留用户数据。2.0.0 安装器为 62,408,254 字节，SHA256 为 5764a9d56c958280966d8d90b9c16f4c6ea89ac03d1a27f95eaeaf7b0b7e7b46。不含开发机账号或模型密钥；安装器未签名，独立新电脑尚未验证。

10 验证结果与证据范围

2026 年 11 月 1 日的提交前复核记录为 713 项完整离线回归通过，0 失败、0 错误；另 15 项安装工具离线测试通过。测试使用独立临时模拟数据，未新增真实银行、本人手机或付费模型验证。不同阶段的测试计数分别留档，不累加成成功率。

证据	实际结果	范围与限制
2026-11-01 源码复核	713 项完整离线回归通过	临时模拟数据库；不调用真实模型 HTTP
安装工具复核	15 项安装工具用例通过	独立于 713 项；不替代真实安装检查
2.0.0 历史安装验收	真实构建、覆盖升级、数据保留与启停已通过	2026-10-28 记录；未签名，独立新电脑未验
模型在线证据	DeepSeek 有分版本真实在线记录	其他四家仅离线接入验证；不推定五家在线通过
本人手机与生产环境	本人现场签收、第二家在线模型等尚未完成	临时身份 TOTP 不等于本人手机；不作生产认证

当前复核依据为随包验收日志及文件指纹；2.0.0 真实安装、升级与浏览器展示证据保留 2026 年 10 月 28 日时点。历史 619、698 等阶段的记录不作为当前源码新通过的证明。

当前验证覆盖包括模型协议和地址边界、授权与越权、幂等及未知结果、资金事务与并发、页面恢复、临时账号与 TOTP、后台租约及启动退出流程。全量计数表示被执行的自动化用例数，不是业务成功率，也不能按历史轮次相加。

五家模型的配置与协议已实现，只有 DeepSeek 具有已归档的真实在线验证记录。本人手机现场签收、第二家在线模型、200%真实桌面缩放和独立新电脑仍待验证；这些范围限制在安全报告中单列。答辩材料随本次提交，演示视频未提供。

11 后续修改与材料维护

界面配色通常只影响截图和展示材料；新增业务或改变业务范围，需要同步场景说明。模型服务商、协议、上下文或地址策略变化，需要更新 API 与数据流章节。资金阈值、周期、评分、份额算法变化，需要重算示例并补充边界验证。身份、密钥、授权、恢复、后台或审计变化，必须同时更新安全自评。

最终提交应冻结源码快照、依赖、材料和测试证据，记录提交号及未提交文件哈希。后续行为改动不能继续沿用旧报告作为新版本通过证明；无需受影响的历史记录仍保留原日期和覆盖范围。

12 主要依据

本文以仓库内当前实现为准。架构与业务依据包括 agent/model_dialogue.py、agent/model_bank.py、shared/contracts.py、shared/policy.py、bank/gateway.py，以及 billing、subscription、wealth、card 目录。模型接入依据为 agent/model_providers.py、agent/model_client.py、agent/model_credentials.py 和 app/model_settings.py。

登录、恢复与后台依据为 bank/auth.py、bank/first_run.py、bank/plan_store.py、bank/worker.py、bank/background.py 及 bank/lifecycle.py。使用方式见源码包内部署说明；模型、身份、资金和审计的风险边界见随附安全自评报告。

当前 713 项回归与 15 项安装工具验证见源码包内 tests 及提交验收记录。2.0.0 的历史构建、安装、升级和浏览器检查单独保留；旧 F1/F2 及其他阶段的在线记录不外推至当前全部代码。

13 最新验证与安装交付

言行 2.0.0 首页突出账户与 AI 入口，六场景共用统一组件、授权反馈和业务回执。未决业务旁可继续提问、澄清、修改草稿和执行允许的纯查询；新写操作仍按冲突与授权检查。unknown 原请求、原键、资金占用及已保存原计划保持，不能靠刷新或清草稿消除。订阅读取需确认，红色真实业务仍需当次动态码。

AUD-06 已修复：未改变的可信执行时间、已完成事实与操作键保持；预算金额修订保留自定义时刻，冲突时拒绝新草稿并保留原计划。历史确定性复现仍留存追溯。

AUD-07 已修复：旧 worker 失去所有权后不再推进新业务。停止状态结合实例退场记录核验，租约过期或审计不可读时显示待核实；已发出的原操作仍按原编号查询。

定时转账备注已补齐：共享契约增加与单笔转账同义的可选 memo，登记、固定到期请求、可信核对、执行与原操作恢复保持一致。旧无备注请求与已登记任务兼容；同幂等键改备注拒绝，不修改付款阈值或授权规则。

本次提交前 713 项完整离线回归及 15 项安装工具用例通过；2.0.0 历史另有 5 项干净启动/后台检查、18 项当期安装工具检查，以及 22 种展示状态、108 次业务块动效检查。各组按日期和维度分别解释，不代表全部设备、全部业务或生产安全已验收。

最近一批已归档的 DeepSeek 页面验证按“白金卡”名称完成冻结、解冻，经临时身份 TOTP 验证，刷新未重复调用。它说明对应版本的接线和恢复行为，不等于本人手机签收，也不能证明其他服务商或当前所有场景重新在线通过。本次材料整理没有新的付费模型调用。

源码包包含当前源码、依赖清单、部署说明、测试用例和必要样例数据，排除个人数据库、账号、密钥、恢复码和开发环境。随附 2.0.0 安装器保留已验收原字节；新提交源码另有署名、材料和测试夹具修订，不能混用旧源码 ZIP 哈希。具体文件以本次 SHA256 清单为准。

14 核心算法与边界算例

14 1 有界任务计划校验

模型计划先检查 JSON 结构、动作与字段白名单，再检查最多 20 个步骤的编号唯一、依赖存在及无环。跨步骤资源引用只允许来自成功祖先回执。执行前重新读取可信账户、卡片、风险档案和预算，不能采用模型自报的身份或“已授权”字段。

14 2 动态授权计算

转账按同一用户跨付款账户、上海执行日内已付款账本累计并加上本笔金额计算；不超过 1000 元需确认，超过需强验证。当前没有把待确认挑战计为日累计额度预占。两笔各 600 元可先分别进入确认；第一笔执行后，第二笔确认时会在执行事务内重算并升级验证。登记预约不等于永久授权，到期及实际执行时仍复验。

14 3 金额与风险匹配

金额以整数分存储，费用及份额用 Decimal 计算，按 HALF_UP 取整；份额保留四位。理财风险问卷使用 R1 至 R5 档位，先完成评估和匹配；例如 R2 用户不能申购 R4 产品，拒绝时不产生申购扣款。理财产品与净值均为虚构；当前申购和赎回在当次事务内即时模拟记账，不含真实跨日清算或 T+1 到账队列。

14 4 幂等与未知结果恢复

写操作绑定用户、动作、参数摘要和幂等键；同键同内容重放返回原结果，同键改参数拒绝。业务、资金与审计在事务或保存点内一致写入。响应丢失时保留 unknown 和原操作键，先查询原结果；NOT_FOUND 本身不能证明未扣款，不自动换新键付款或释放可能已经消费的预留。